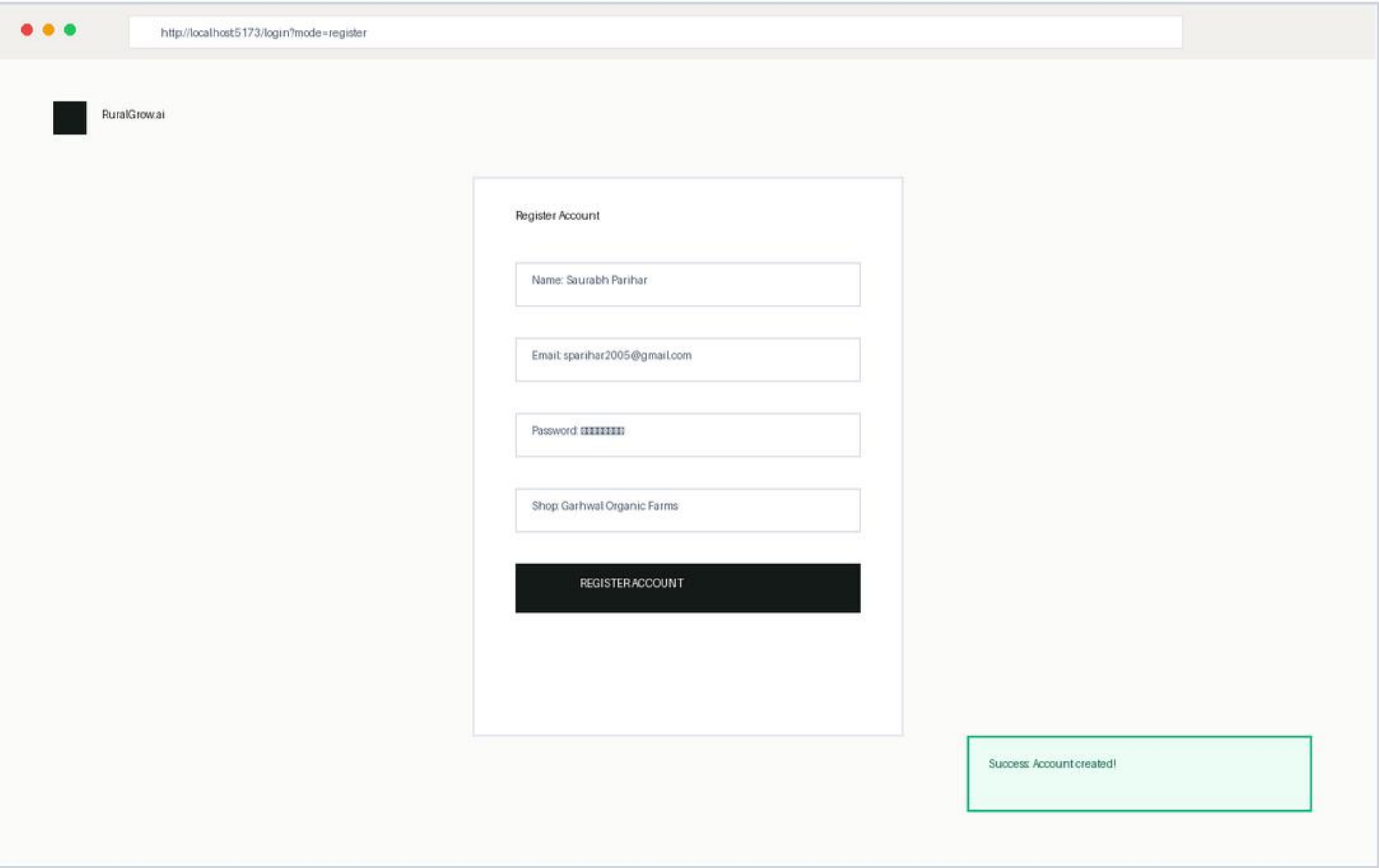


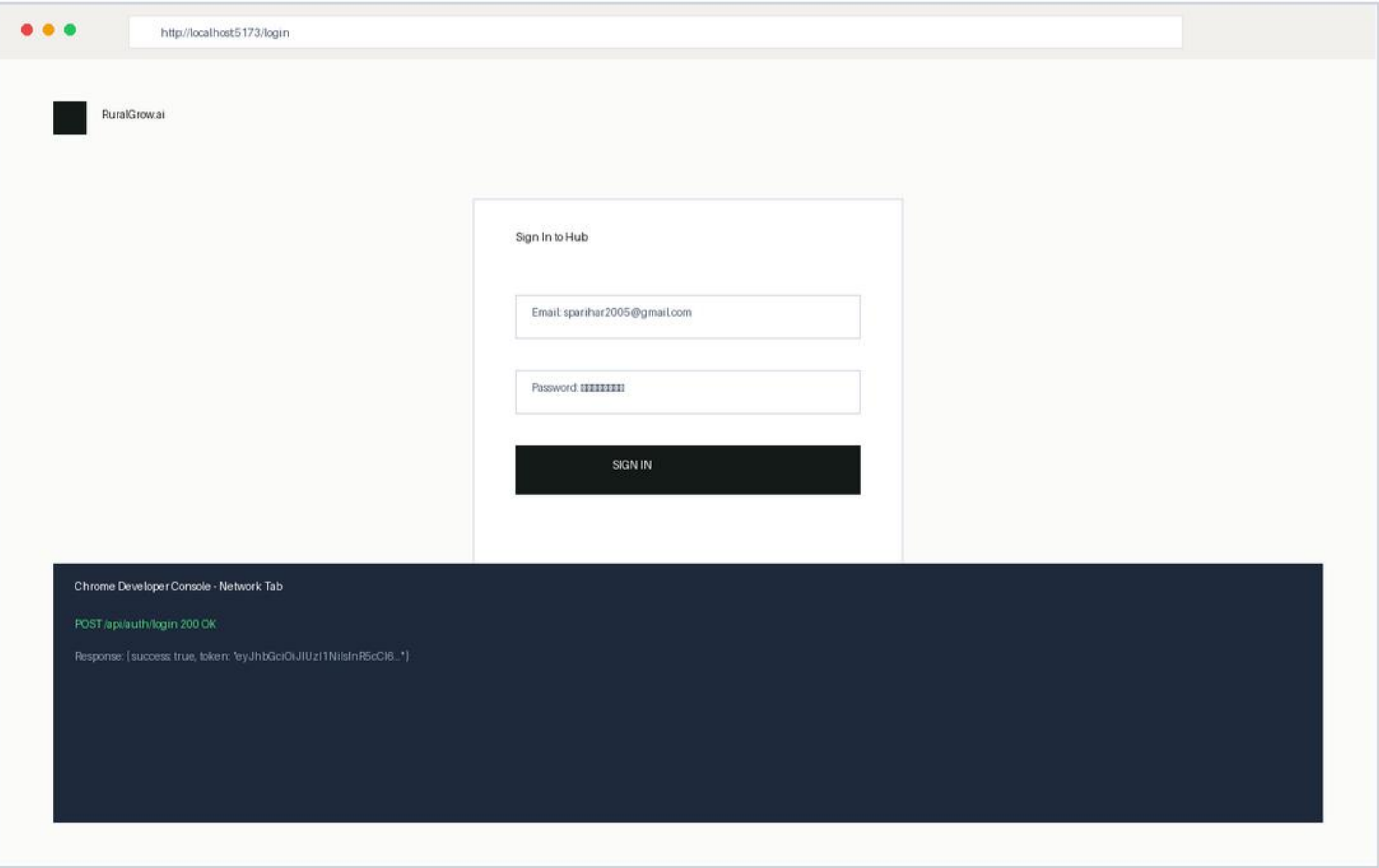
Figure 1: User Registration Flow (/register)



CAPTION NOTE:

This page displays the user registration flow. Request inputs (name, email, password) are processed by Zod validations and saved in MongoDB using bcrypt. Re-registering with the same email returns a 400 Bad Request error.

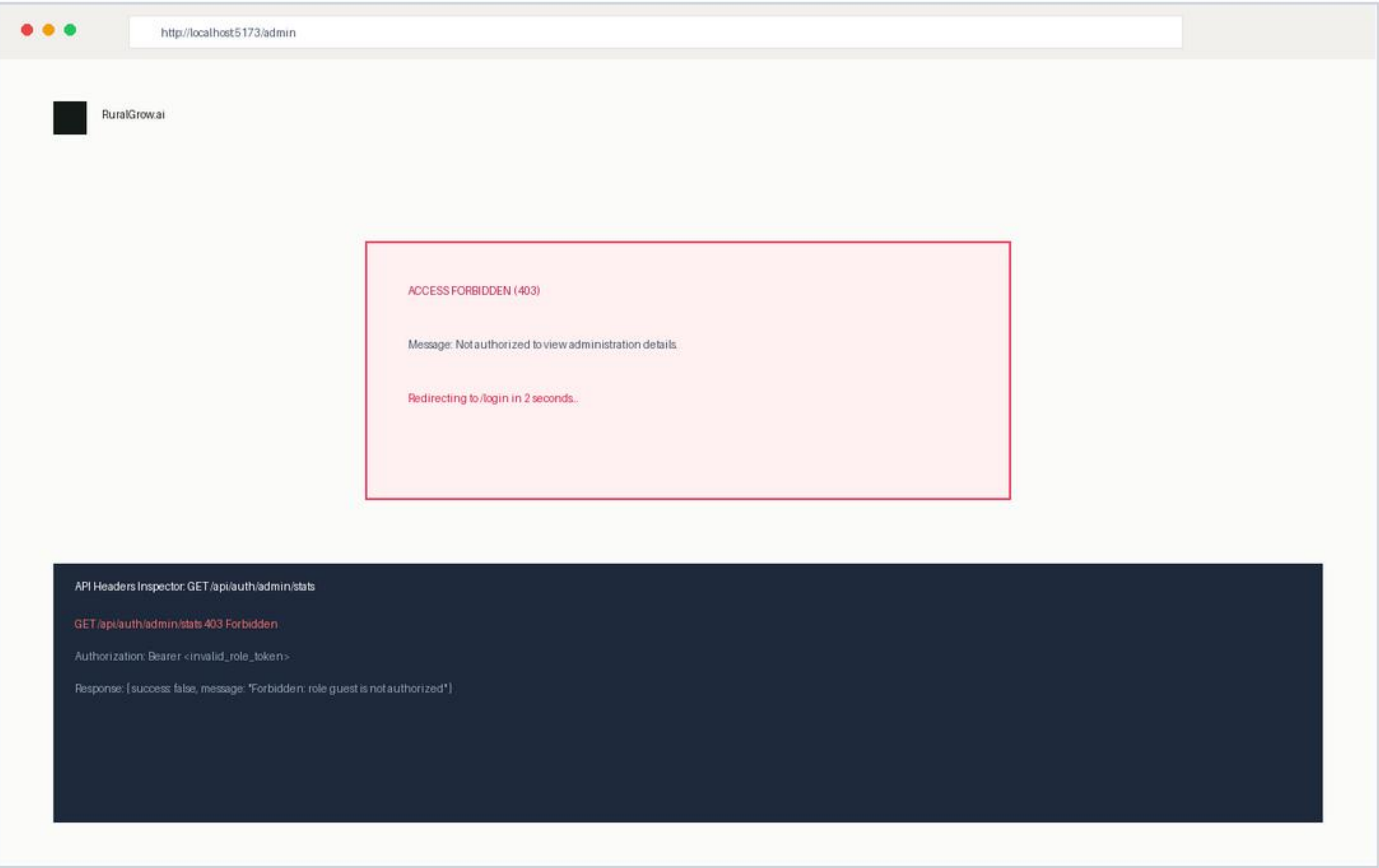
Figure 2: User Login Flow (/login)



CAPTION NOTE:

This page documents the user sign-in process. Sending matching credentials to `/api/auth/login` returns a success response with a signed JSON Web Token (JWT) expiring in 7 days, which is stored in the client's `localStorage`.

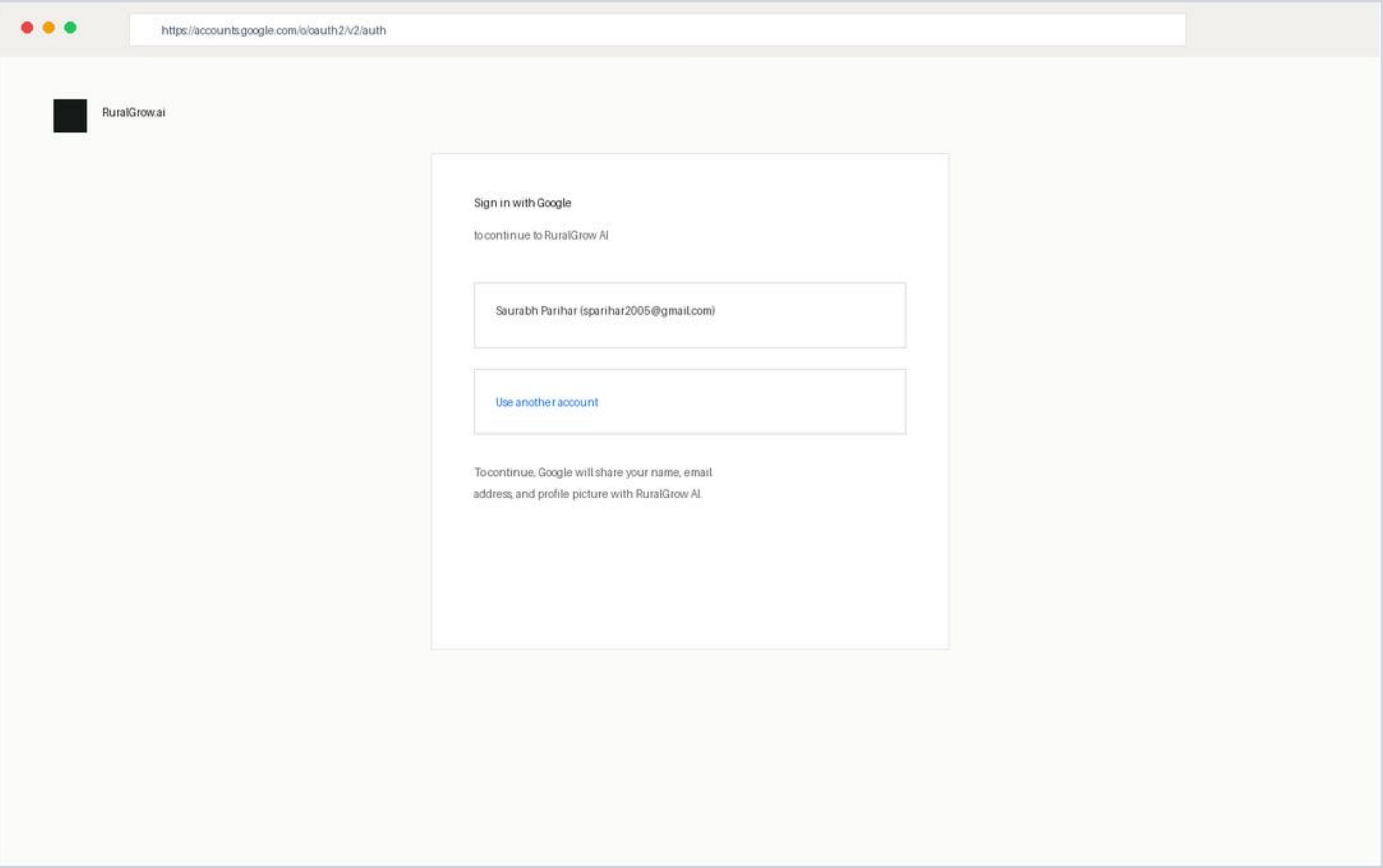
Figure 3: Protected Routes & Role Authorization



CAPTION NOTE:

This page verifies route security. Attempting to fetch protected API data without a valid header token returns a 401 Unauthorized error. Attempting to fetch admin routes with a non-admin token returns a 403 Forbidden error, redirecting back to login.

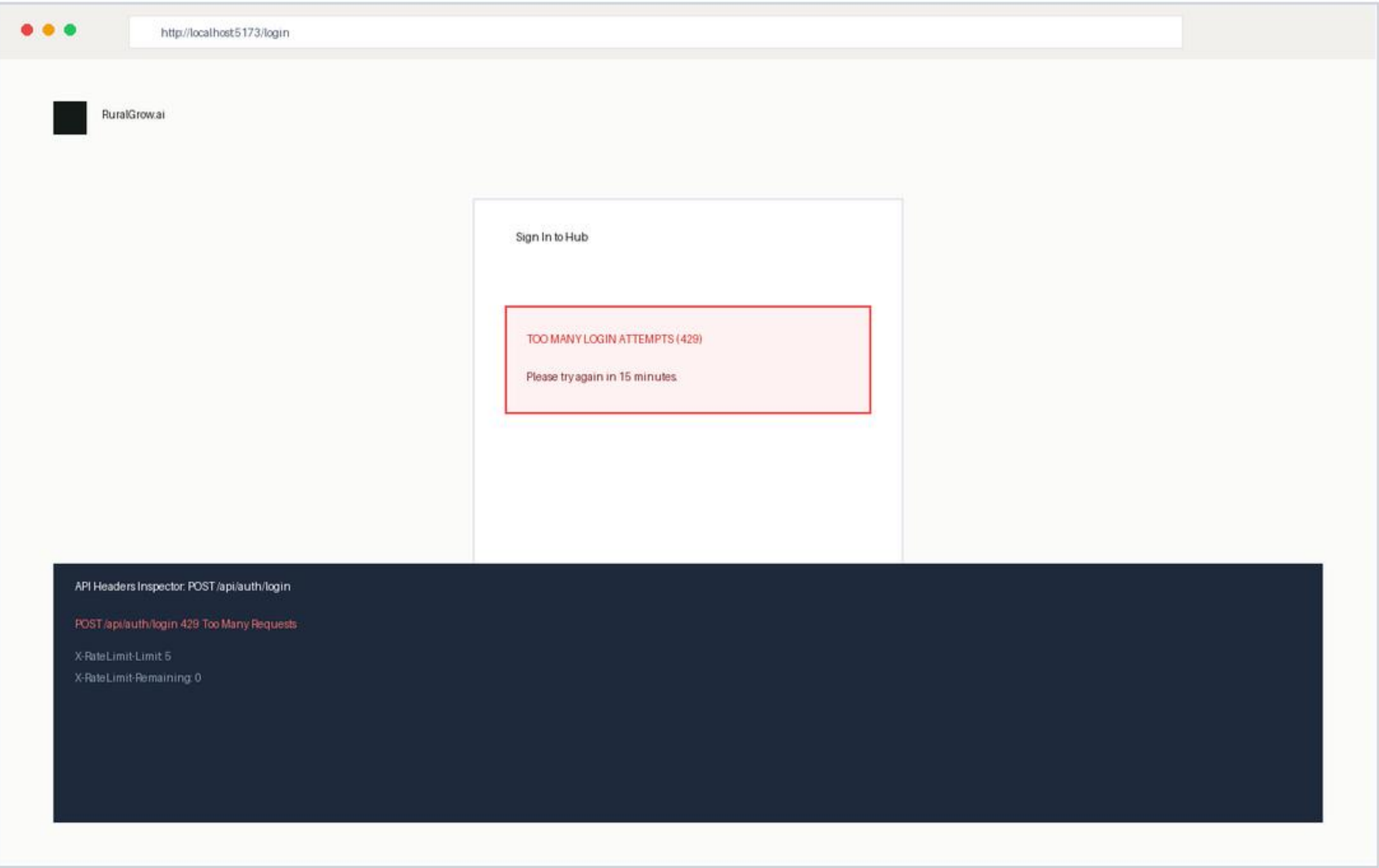
Figure 4: Google OAuth 2.0 Integration



CAPTION NOTE:

This page documents Google OAuth registration. Clicking 'Login with Google' triggers the passport-google-oauth20 strategy on the backend, redirecting the user to the Google Account consent screen. The token callback registers the user and creates a session.

Figure 5: API Rate Limiter Verification (429)



CAPTION NOTE:

This page displays the rate limiter active on auth endpoints. Attempting to register or log in repeatedly (exceeding 5 requests within 15 minutes) triggers the express-rate-limit middleware, blocking subsequent attempts and returning a 429 response.